

Relatório Técnico de Análise de Malware

Sumário

1. Apresentação
2. Resumo Executivo
3. Montagem do Laboratório e Ferramentas utilizadas
4. Identificação da ameaça
5. Contexto da ameaça
6. Vetores de Infecção
7. Resultados da análise
    a. Análise estática
    b. Análise dinâmica
8. Mapeamento do MITRE ATT&CK
9. Impacto potencial
10. Medidas de mitigação
11. Conclusão
12. Perguntas respondidas

1. Apresentação

Malware Investigado: mydoom.a (Worm)

Data: 22/08/2025

Analista Responsável: Mauricio Robert e André Luiz

Organização: Impacta

2. Resumo Executivo

Este relatório apresenta os resultados de uma análise conduzida sobre o malware **Mydoom.A**, uma ameaça conhecida por sua capacidade de se propagar rapidamente via e-mail e criar backdoors em sistemas Windows.

O Mydoom.A utiliza **engenharia social** para induzir o usuário a executar o arquivo malicioso (f-mydoom.exe) e, uma vez instalado, modifica o sistema criando chaves de registro e arquivos maliciosos para garantir **persistência**.

3. **Montagem do laboratório e ferramentas utilizadas**

   A análise foi conduzida em um laboratório em uma V.M. isolado e controlado, seguindo as boas práticas de segurança.

   Ferramentas utilizadas:

   ISO: https://archive.org/download/win-10-1803-english-x-64/Win10_1803_English_x64.iso

   Estática: PEStudio e Virus Total

   Dinâmica: Procmon, Process Explorer, WireShark e TCPView

4. **Identificação da ameaça**

- **Nome da Família:** mydoom.a
- **Classificação:** Worm / Vírus
- **Hash SHA256:** FFF0CCF5FEAF5D46B295F770AD398B6D572909B00E2B8BCD1B1C286C70CD9151
- **Origem da Amostra:** Capturada em ambiente controlado: Virtual Machine
- **Data da Captura:** 19/08/2025

5. **Contexto da ameaça**

   O **Mydoom.A** surgiu em 2004 e rapidamente se tornou um dos worms mais rápidos e disseminados da época, principalmente por meio de e-mails infectados e redes P2P.

   Inicialmente, seu objetivo principal era **propagação em massa**, explorando a curiosidade e a confiança do usuário por meio de **engenharia social** — anexos ou links aparentemente inofensivos que, ao serem abertos, executavam o malware.

   Com o tempo, o Mydoom.A mostrou ser capaz de realizar várias atividades maliciosas de forma silenciosa:

   - **Backdoor e controle remoto:** cria uma porta de acesso (porta 3127) para permitir que invasores controlem o computador da vítima.
   - **Modificação do sistema:** altera o registro do Windows e cria arquivos DLL maliciosos (shimgvw.dll, shimgapi.dll) para se manter ativo mesmo após reinicializações.
   - **Propagação e ataque a redes:** envia spam, realiza varreduras em outros computadores e pode ser usado para ataques de negação de serviço.

O Mydoom.A foi um exemplo precoce de como um malware podia **combinar engenharia social com técnicas de persistência e rede**, tornando-se perigoso e difícil de conter, mesmo sem depender de exploits sofisticados.

6. Vetores de infecção

Como neste caso estamos estudando-o, baixamos no repositório TheZoo no GitHub.

Porém em casos reais ele poderia se propagar por meio de:

- **Via Phishing:** Com as máquinas infectadas enviava links contendo o malware para os outros.
- **Redes P2P:** Compartilhamento de arquivos em redes P2P como Kazaa ou LimeWire. Utilizava Músicas, Filmes ou programas para se propagar.

7. Resultados da análise

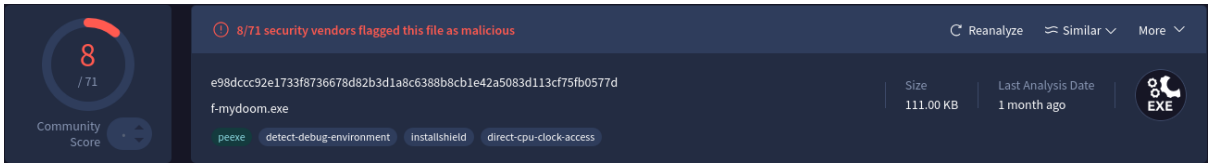
a. Análise estática

- O malware possui o sha256 idêntico, porém seu inicializador tem seu hash diferente.
- Para começar o processor tem que abrir o f-mydoom.exe, para que o "payload":strip-grils funcione.
- Valor de entropy - 6.137
- Não utiliza GUI
- Utiliza o DOS para seu funcionamento

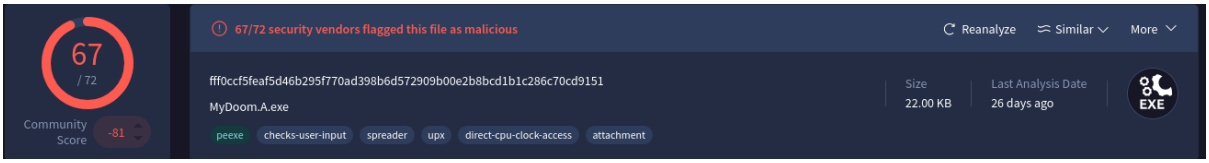
property	value
footprint > sha256	E98DCCC92E1733F8736678D82B3D1A8C6388B8CB1E42A5083D113CF75FB0577D
first-bytes-hex	4D 5A 90 00 03 00 00 00 04 00 00 00 FF FF 00 00 B8 00 00 00 00 00 00 00 40 00 00 00 00 00 00 00
first-bytes-text	M Z . . . . . @ . . . . .
file > size	113664 bytes
entropy	6.137
signature	Microsoft Visual C++
tooling	n/a
file-type	executable
cpu	32-bit
subsystem	console
file-version	n/a
description	n/a

Malware values

- Seu score no **Virus total** é de 67/72 o strip e o mydoom é 8/71



Virus Total – mydoom.a



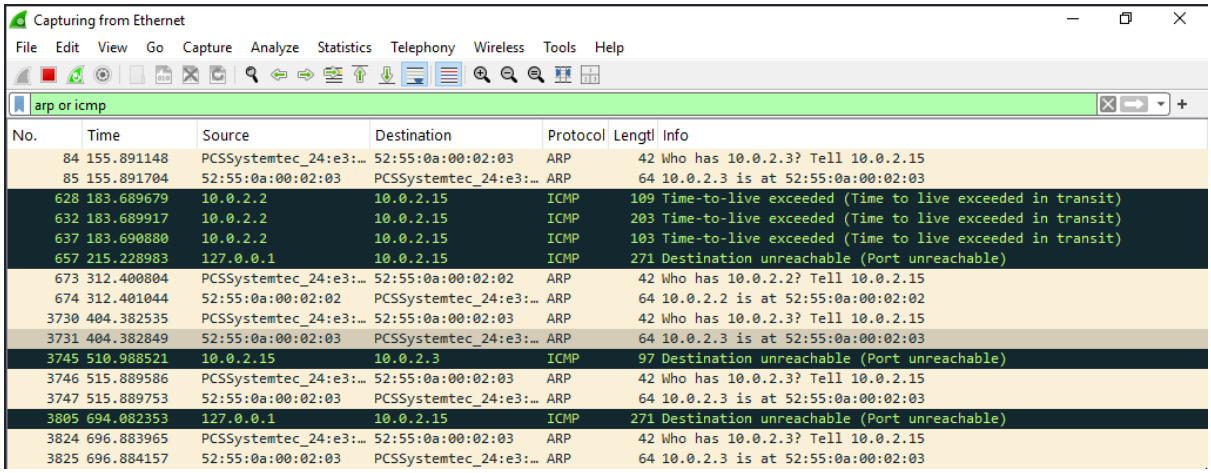
Virus Total – step-grill

b. Análise dinâmica

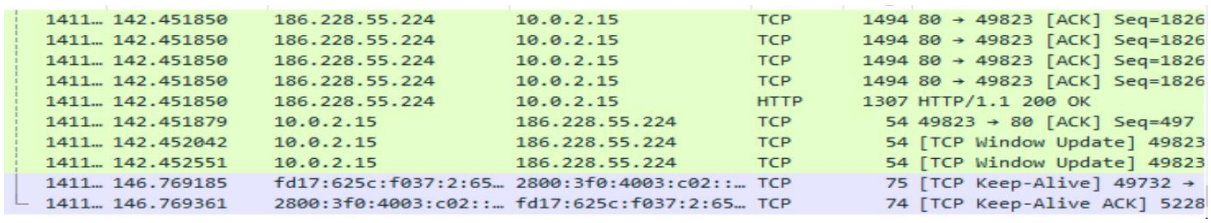
- Com o início do malware, foram iniciados =~1.500.000 processos, dentre eles como criação, leitura e saída de pastas; além de mudanças de políticas.
- **Execução do Malware**
- O binário inicia com comportamento aparentemente normal, mas rapidamente executa atividades suspeitas.
- **Criação de Processos e Persistência**
- Novos processos são gerados em segundo plano, usando nomes semelhantes a processos legítimos do Windows.
- Indícios de persistência via alterações no Registro ou criação de tarefas agendadas.
- **Atividade em Rede**
- Conexões de saída para endereços externos utilizando portas incomuns.
- Possível comunicação com servidor de Command & Control (C2) via HTTP/HTTPS ofuscado.
- **Modificações no Sistema**
- Alterações em diretórios temporários e no perfil do usuário.
- Criação de arquivos aleatórios, possivelmente contendo payloads adicionais ou logs.
- Alterações no Registro para execução automática.
- **Evasão e Técnicas Anti-Análise**
- Finaliza ferramentas de monitoramento e dificulta encerramento manual do processo.
- Executa partes de sua rotina em memória, reduzindo artefatos visíveis no disco.
- **Impacto Observado**
- Lentidão do sistema e tráfego contínuo para IPs externos, indicando exfiltração de dados ou beaconing.
- **Início do Malware 3:40:59 PM – Fim do Malware 3:43:02 PM**
- Com o início do malware, novos processos foram gerados em segundo plano, muitos utilizando nomes semelhantes a processos legítimos do Windows, indicando tentativa de camuflagem e persistência.

- O malware acessou diretórios temporários, o perfil do usuário e o Registro do Windows, sugerindo criação de arquivos aleatórios para payloads adicionais ou logs de execução, além de configurar execução automática.
- Durante a execução, o malware estabeleceu conexões de saída para endereços externos usando portas incomuns. Há indícios de comunicação com servidores de Command & Control (C2), possivelmente via HTTP/HTTPS ofuscado, caracterizando beaconing ou exfiltração de dados.
- Foram observadas tentativas de evasão, como finalização de ferramentas de monitoramento e execução em memória, reduzindo a presença de artefatos visíveis no disco e dificultando a análise manual.
- O impacto percebido incluiu lentidão do sistema e tráfego de rede contínuo. Não houve sinais claros de ransomware ou destruição de arquivos, reforçando o perfil de trojan/backdoor com potencial para execução remota de comandos ou download de payloads adicionais.

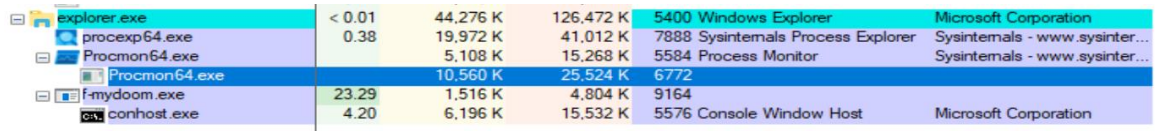
➢ Evidências:



ICMP or ARP Tráfego



ACK pack



f-mydoom



Alto consumo de processamento



Persistência criada

8. **Mapeamento do MITRE ATT&CK**

- **T1071.001 – Application Layer Protocol: Web Protocols**
- **T1071.004 – Application Layer Protocol: DNS**
- **T1071.002 – Application Layer Protocol: SMB/Netlogon**
- **T1059.003 – Command and Scripting Interpreter: Windows Command Shell**
- **T1059.005 – Command and Scripting Interpreter: PowerShell**
- **T1547.001 – Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder**
- **T1053.005 – Scheduled Task: Scheduled Task / Job**
- **T1078.003 – Valid Accounts: Local Accounts**
- **T1078.002 – Valid Accounts: Domain Accounts**
- **T1070.004 – Indicator Removal on Host: File Deletion**
- **T1070.002 – Indicator Removal on Host: Indicator Removal from Tools**
- **T1081 – Credentials in Files**
- **T1083 – File and Directory Discovery**
- **T1082 – System Information Discovery**
- **T1021.002 – Remote Services: SMB/Windows Admin Shares**
- **T1021.001 – Remote Services: Remote Desktop Protocol**

- **T1074.001 – Data from Local System: Local System Files**
- **T1074.002 – Data from Local System: Application Layer Protocols**
- **T1041 – Exfiltration Over Command and Control Channel**
- **T1048.003 – Exfiltration Over Alternative Protocol: DNS**
- **T1499 – Endpoint Denial of Service**
- **T1486 – Data Encrypted for Impact**

9. Impacto potencial

- **Lentidão e instabilidade do sistema**: O worm consome recursos do computador, gerando degradação de desempenho.
- **Movimentação lateral e comprometimento de rede**: Pode se espalhar via compartilhamentos SMB e RDP, afetando outros computadores na rede.
- **Exfiltração de dados**: Possível envio de informações do sistema ou arquivos para servidores de Command & Control (C2).
- **Abertura de backdoor**: Permite execução remota de comandos e download de payloads adicionais.
- **Negação de serviço em endpoints**: Consumo excessivo de recursos pode travar ou tornar sistemas indisponíveis.

10. Medidas de Mitigação

- Mantenha sistemas, aplicativos e serviços sempre atualizados.
- Utilize antivírus, EDR e filtragem de e-mails para bloquear malwares e anexos suspeitos.
- Use contas com privilégios mínimos e desative serviços vulneráveis (SMBv1, RDP).
- Isole sistemas infectados e monitore tráfego de rede incomum.
- Remova arquivos maliciosos, tarefas agendadas e revise credenciais comprometidas.
- Treine usuários para não abrir anexos suspeitos ou clicar em links desconhecidos.

11. Conclusão

A análise do Mydoom.A evidencia como um malware antigo ainda representa lições valiosas para a segurança moderna. Apesar de sua origem em 2004, suas técnicas de propagação rápida, persistência silenciosa, abertura de backdoors

e exfiltração de dados demonstram a sofisticação com que malwares podem explorar engenharia social e vulnerabilidades do sistema.

Durante os testes realizados em ambientes controlados com sistemas atuais (Windows 10 em VM isolada), não foram observados impactos críticos típicos de sistemas legados, como travamentos ou falhas graves. Isso reforça que muitas das ações do malware, embora efetivas em máquinas antigas, hoje encontram barreiras naturais devido a mecanismos modernos de segurança, atualizações de sistema e controle de privilégios.

A avaliação reforça a importância de manter sistemas atualizados, controlar privilégios, monitorar tráfego de rede e conscientizar usuários sobre práticas seguras. O aprendizado obtido com esta análise não se limita ao Mydoom.A, mas serve como guia para prevenção, detecção e resposta a ameaças similares, fortalecendo a postura de segurança de qualquer organização.

12. Perguntas respondidas

1. Alterações no Sistema

1.1 Principais chaves do registro criadas:

- HKCR\CLSID{529A9E6B-6587-4F23-AB9E-9C7D683E3C50}
- HKCU\Software\Microsoft\Windows\CurrentVersion\Run
- Criação de arquivos temporários em: C:\Users\Nistezy\AppData\Local\Temp

1.2 Artefatos criados pelo malware:

- Arquivo shimgvw.dll
- Logs temporários
- Aumento no consumo de CPU e memória RAM

1.3 Processo que inicia a atividade maliciosa:

- f-mydoom.exe

1.4 Subprocessos maliciosos:

- conhost.exe
- Processos legítimos do Windows (utilizados para camuflagem)

1.5 DLLs afetadas:

- apphelp.dll
- shimgapi.dll
- wsock32.dll

2. Persistência

- Mantida através da chave do registro:
  HKCU\Software\Microsoft\Windows\CurrentVersion\Run
- Utilização de arquivos temporários para reinício e execução contínua

3. Atividades de Rede

3.1 Conexões e domínios:

- Realiza varreduras de rede e tentativas de conexão
- Tenta acessar domínios codificados que fornecem instruções ao malware, variando conforme a versão

4. Vulnerabilidades exploradas:

- Engenharia social (exploração da vulnerabilidade humana)
- Criação de backdoor na porta 3127, permitindo controle remoto